

Zapora sieciowa.

Plan wykładu

- ▶ Wprowadzenie
- ▶ Zapory ogniowe
- ▶ Systemy IDS
- ▶ Systemy IPS
- ▶ Systemy UTM
- ▶ Podsumowanie

Plan wykładu

- ▶ **Wprowadzenie**
- ▶ Zapory ogniowe
- ▶ Systemy IDS
- ▶ Systemy IPS
- ▶ Systemy UTM
- ▶ Podsumowanie

Zapora sieciowa, znana także jako firewall, to element systemu zabezpieczeń komputerowych, który kontroluje ruch sieciowy między sieciami o różnym stopniu zaufania.

Głównym celem zapory sieciowej jest ochrona sieci przed nieautoryzowanym dostępem, atakami sieciowymi oraz kontrola przepływu danych.

Istnieje kilka rodzajów zapór sieciowych, ale najczęściej spotykane to:

1. Zapory pakietów (Packet Filtering Firewalls):

- Kontrolują ruch sieciowy na podstawie informacji zawartych w nagłówkach pakietów danych.
- Decyzje dotyczące przepuszczania lub blokowania pakietów podejmowane są na podstawie predefiniowanych reguł.
- Są stosunkowo szybkie, ale operują na warstwie sieciowej modelu OSI.

2. Zapory stanowe (Stateful Inspection Firewalls):

- Monitorują stan połączeń sieciowych i podejmują decyzje na podstawie kontekstu, a nie tylko informacji zawartych w nagłówkach pakietów.
- Zdolne do analizy stanu sesji i śledzenia, czy dane pakiety są częścią legalnego przepływu komunikacji.

Bardziej zaawansowane niż zapory pakietów.

3. Zapory warstwowe (Proxy Firewalls):

- Działają na poziomie aplikacji (warstwy aplikacyjnej modelu OSI).
- Odczytują, analizują i decydują o danych przekazywanych między klientem a serwerem.
- Mogą pełnić rolę pośrednika między użytkownikiem a zasobami internetowymi, co pomaga w ukryciu struktury sieci wewnętrznej.

4. Zapory aplikacyjne (Application Layer Firewalls):

- Obejmują zarówno funkcje zapory warstwowej, jak i stanowej.
- Skoncentrowane są na kontroli ruchu na poziomie aplikacji, umożliwiając dokładne monitorowanie i filtrowanie danych w oparciu o konkretne aplikacje czy protokoły.

Funkcje i cechy zapór sieciowych obejmują:

.Filtrowanie ruchu: Decydują, które pakiety mogą przechodzić przez sieć, a które powinny zostać zablokowane.

.NAT (Network Address Translation): Maskowanie adresów IP wewnętrznych przed adresami IP zewnętrznymi, co zwiększa bezpieczeństwo sieci.

.VPN (Virtual Private Network): Zapory mogą obsługiwać połączenia VPN, umożliwiające bezpieczną komunikację między oddalonymi lokalizacjami.

.Logging i audytowanie: Rejestrowanie aktywności sieciowej w celu analizy zdarzeń i identyfikacji potencjalnych zagrożeń.

Współczesne zapory sieciowe są kluczowym elementem infrastruktury bezpieczeństwa, chroniąc przed różnymi atakami, takimi jak ataki DDoS, próby przełamania zabezpieczeń czy nieautoryzowany dostęp. Wdrażane są zarówno w środowiskach korporacyjnych, jak i indywidualnych, aby zapewnić skuteczną ochronę sieci.

Wprowadzenie

- ▶ Obecnie na rynku istnieje **wiele** systemów kontroli ruchu sieciowego, różniących się zasadami działania
- ▶ Umożliwiają one administratorom sieci **dopasować** do potrzeb organizacji konfigurację i stworzenie najbardziej pożądanej architektury
- ▶ Podstawowe systemy kontroli ruchu sieciowego to **firewall** (zapora ogniowa), systemy **IDS** (Intrusion Detection System), systemy **IPS** (Intrusion Prevention System)
- ▶ Obecnie często wiele funkcji bezpieczeństwa jest integrowana w jednym urządzeniu nazywanym **UTM** (Unified Threat Management)

Wprowadzenie

Systemy kontroli ruchu sieciowego oprócz funkcji związanych z bezpieczeństwem mogą realizować:

- ▶ **Filtrowanie ruchu** w celu cenzury, wyszukiwania określonych treści
- ▶ **Ograniczanie pasma** w celu ograniczenia ruchu generowanego przez użytkowników
- ▶ **Zbieranie informacji** o charakterystyce ruchu sieciowego

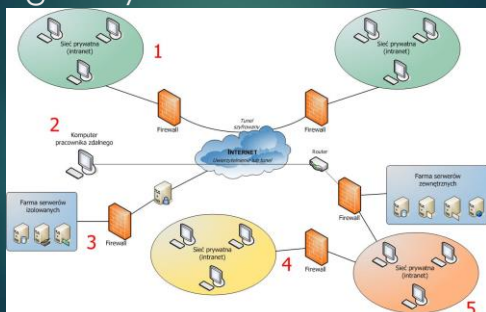
Plan wykładu

- ▶ Wprowadzenie
- ▶ **Zapory ogniowe**
- ▶ Systemy IDS
- ▶ Systemy IPS
- ▶ Systemy UTM
- ▶ Podsumowanie

Zapora ogniowa

- ▶ Zaporą ogniową (ang. *firewall*) nazywamy **punkt przejścia** w systemie komunikacyjnym między siecią LAN lub siecią korporacyjną, a światem zewnętrznym, czyli siecią rozległą
- ▶ Zapora ogniowa może być utworzona z jednego lub wielu **urządzeń** i/lub specjalistycznego **oprogramowania** Unix, Windows, Linux, Novell NetWare
- ▶ Podstawowa zasada działania zapory ogniowej to **kontrola i analizowanie** ruchu przychodzącego z zewnątrz i wychodzącego na zewnątrz oraz ruchu przesyłanego wewnątrz chronionej sieci lokalnej
- ▶ Firewall może być więc traktowany jako **logiczny separator**, ogranicznik i analizator

Zastosowania zapór ogniowych



Zastosowania zapór ogniowych

1. Połączenie dwóch sieci chronionych szyfrowanym tunelem (np. VPN) poprzez sieć o niskim poziomie zaufania (Internet)
2. Identyfikacja i uwierzytelnianie użytkownika mobilnego przy dostępie do sieci wewnętrznej
3. Zabezpieczenie serwerów i udostępnienie jedynie wybranych usług
4. Rozdzielenie sieci chronionych na strefy bezpieczeństwa o różnym poziomie zaufania
5. Ochrona sieci prywatnej przed nieautoryzowanym dostępem z Internetu

Funkcje zapór ogniowych

- Ochrona przed włamaniami z zewnątrz
- Informowanie o potencjalnych zagrożeniach

Technologie kontroli ruchu

- ▶ **Filtrowanie pakietów** (ang. *Packet Filtering*). Selekcja i odrzucanie pakietów z nieautoryzowanych hostów oraz zapobieganie próbom połączenia z nieautoryzowanych hostów
- ▶ **Translacja** (maskowanie, maskarada) adresów sieciowych (ang. *Network Address Translation*). Polega na zmianie adresu hosta wewnętrznego w celu ukrycia go
- ▶ **Brama warstwy aplikacyjnej** (ang. *Proxy Service*). Informacje przechodzą przez specjalną aplikację, która obsługuje wybrane przez administratora aplikacje TCP

Filtrowanie pakietów IP

- ▶ Proste filtry funkcjonują na poziomie pakietów IP i próbują je identyfikować w zależności od **adresów źródłowych i docelowych**
- ▶ Można analizować **porty TCP** identyfikujące usługi oraz inne pola w nagłówkach IP, TCP, UDP
- ▶ Filtry **nie pozwalają** na dokładne analizowanie danych związanych z usługami i **protokołami wyższych warstw** np. HTTP
- ▶ Główna zaleta filtrowania to **duża szybkość**

Filtr bezstanowy

- ▶ Zadanie **filtra bezstanowego** (ang. *Stateless*) polega na analizie informacji zawartej w nagłówku każdego pakietu oraz podjęciu decyzji o przepuszczeniu bądź odrzuceniu badanego pakietu
- ▶ Większość filtrów dopuszcza filtrowanie w oparciu o następujące **pola nagłówka**: adres IP, typ protokołu, port TCP/IP, informacji dotyczącej wyboru trasy, znaczniku fragmentu
- ▶ Najczęściej wykorzystywaną informacją do filtrowania jest informacja o **portach TCP lub UDP**, ponieważ pola te określają najbardziej szczegółowo przeznaczenie pakietu

Filtr bezstanowy – wady

- ▶ Do analizy pobierają informacje **tylko z nagłówka**, natomiast nie są w stanie zbadać części z ładunkiem danych pakietu (ang. *Payload*) pod kątem zawierania niebezpiecznych lub źle sformatowanych danych
- ▶ **Nie zapamiętują stanu połączenia**, ponieważ nie przechowują informacji o porcie usługi związanej z przesyłanymi pakietami

Filtr z badaniem stanów

- ▶ Zasada działania filtra z **badaniem stanów** (ang. *Stateful Inspection*), polega na bieżącym analizowaniu przechodzących przez dany węzeł połączeń, co pozwala na skuteczniejszą kontrolę ich legalności
- ▶ Przechowuje informacje o stanie **całego** przechodzącego ruchu pakietów na poziomie warstwy sieciowej oraz transportowej, wiedząc jakie kolejne stany zostały dozwolone z punktu widzenia protokołu, jak i polityki bezpieczeństwa
- ▶ Pozwala na określenie możliwości **zrealizowania** danego połączenia bez konieczności operowania stanami TCP

Filtr z badaniem stanów

- ▶ **Automatycznie** weryfikuje kolejne etapy nawiązania oraz późniejszy przebieg połączenia
- ▶ Pozwala to na **odrzućcie pakietów**, które nie należą do danej sesji, co w praktyce przekłada się na skuteczne blokowanie ataku poprzez wprowadzanie sfałszowanych pakietów (ang. *Spoofing*) oraz pozwala na blokowanie prób skanowania portów
- ▶ Decyzja o losie pakietu podejmowana jest na podstawie **całego strumienia** komunikacyjnego, a nie pojedynczych pakietów
- ▶ Pozwala to **wykryć** próby niepoprawnych połączeń i planowanych ataków na sieć lokalną

Translacja adresów w zaporach ogniowych

- ▶ Mechanizm **NAT** (Network Address Translation) pozwala zmieniać prywatne adresy IP znane wewnątrz chronionej sieci na wykorzystywane w Internecie unikatowe adresy IP
- ▶ Dzięki temu można **ukryć** wewnętrzną strukturę adresacji IP
- ▶ Mechanizm NAT często współpracuje z mechanizmem **PAT** (Port Address Translation)

Poziom aplikacji - bramy i proxy

- ▶ Proxy początkowo służyły do **przechowywania w pamięci** podręcznej często przeglądanych stron WWW
- ▶ Obecnie używa się ich do **filtrowania** oraz **ukrywania** użytkowników sieci za pojedynczym komputerem
- ▶ Serwery proxy zwykle umieszcza się **między** wewnętrznym użytkownikiem sieci lokalnej, a daną usługą w Internecie
- ▶ Proxy jest więc **przeźroczystym interfejsem** między siecią LAN i WAN kontrolującym ruch do warstwy siódmej

Poziom aplikacji - bramy i proxy

- ▶ Usługa pośredniczenia, jest efektywna dopiero **w połączeniu** z hostami wielosieciowymi oraz filtrami pakietów, odpowiedzialnymi za ograniczenie bezpośredniej komunikacji pomiędzy zewnętrznymi i wewnętrznymi komputerami
- ▶ Filtrowanie na wyższych warstwach umożliwia **ustalenie związków** między pakietami tego samego połączenia
- ▶ Dodatkowo usytuowanie bram aplikacji w warstwie siódmej ułatwia implementację **uwierzytelniania i szyfrowania**

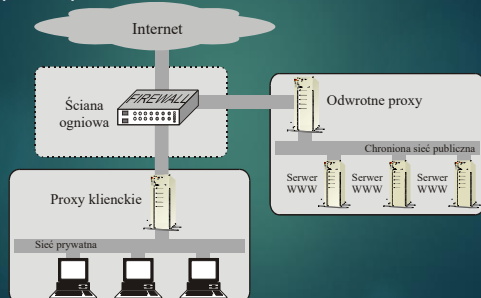
Zalety serwerów proxy

- ▶ **Ukrywa** wewnętrznego użytkownika przed dostępem z Internetu
- ▶ **Blokuje** dostęp do wybranych adresów WWW w oparciu o ich adres URL.
- ▶ **Filtruje** dane pod kątem podejrzanej zawartości, wyszukując wirusy i konie trojańskie, niechciane treści
- ▶ **Bada spójność** przesyłanej informacji pod kątem nieprawidłowo sformatowanych danych
- ▶ Zapewnia **pojedynczy** punkt dostępu, nadzorowania oraz rejestrowania zdarzeń

Wady serwerów proxy

- ▶ Proxy stanowi **pojedynczy punkt** w sieci lokalnej, który w każdej chwili może ulec awarii
- ▶ Oprogramowanie klienta musi **współpracować** z proxy
- ▶ **Każda usługa** musi posiadać swoje **własne proxy**
- ▶ Proxy **nie chroni** podstawowego **systemu operacyjnego**
- ▶ Konfiguracje **domyślne** są często optymalizowane z punktu widzenia wydajności, a nie bezpieczeństwa
- ▶ Serwery proxy tworzą **zatory**

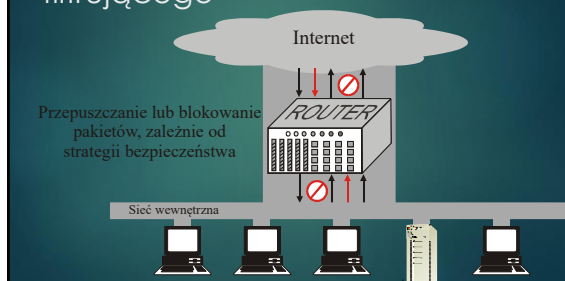
Architektura bezpiecznego proxy



Elementy składowe zapory ogniowej

- ▶ **Router filtrujący (ekranujący)** (ang. *Screening router SR*). Jego zadanie to filtrowanie pakietów
- ▶ **Bastion** (ang. *bastion host BH*). Bastion to wewnętrzny serwer, który potrafi monitorować i analizować najważniejsze obszary bezpieczeństwa sieci. Zazwyczaj jest przygotowany na pokonanie podstawowych zagrożeń znanych w sieciach TCP/IP. Powinien posiadać funkcję zgłaszania wykrytych zagrożeń.
- ▶ **Brama aplikacyjna** (ang. *application level gateway*). Brama aplikacyjna to rozszerzona wersja bastionu. Dodatkowo zaimplementowana jest funkcja proxy aplikacyjnego, który umożliwia dokładne kontrolowanie i analizowanie poszczególnych aplikacji, dokonywanie zapisu i audytu analizowanych danych

Zapora ogniowa zbudowana z routera filtrującego



Zapora ogniowa zbudowana z routera filtrującego

Przedstawione rozwiązanie jest funkcjonalne pod warunkiem gdy:

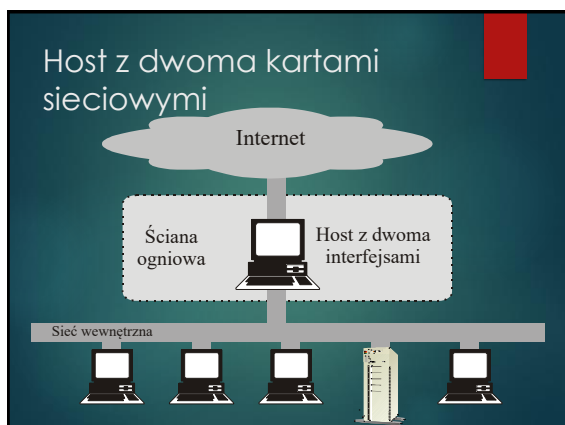
- ▶ Hosty umieszczone w chronionej sieci są dobrze **zabezpieczone**
- ▶ Używana jak **niewielka** ilość protokołów o niskiej złożoności
- ▶ Priorytetową cechą zapory ma być **wysoka wydajność**

Zapora ogniowa zbudowana z routera filtrującego

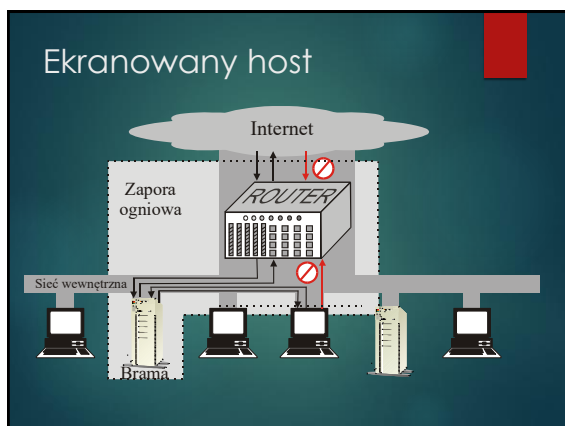
W celu programowanie routera **należy**:

- ▶ Zablokować wszystkie pakiety **nieużywanych** usług
- ▶ Zablokować wszystkie pakiety z opcją **rutingu źródłowego**
- ▶ **Zezwalać** na połączenia TCP **przychodzące** z **określonych** serwerów sieciowych oraz blokować pozostałe połączenia
- ▶ **W razie konieczności** zezwalać hostom z sieci lokalnej na połączenia TCP na zewnątrz do dowolnego hosta w Internecie

Host z dwoma kartami sieciowymi



Ekranowany host



Ekranowany host

Zadania routera:

- ▶ Blokowanie usług nie wykorzystywanych w wewnętrznej sieci
- ▶ Blokowanie pakietów przesyłanych z routinglem źródłowym
- ▶ Blokowanie pakietów, których miejscem przeznaczenia jest sieć wewnętrzna, a przepuszczanie tych pakietów, których źródłowym bądź docelowym adresem IP jest adres bramy

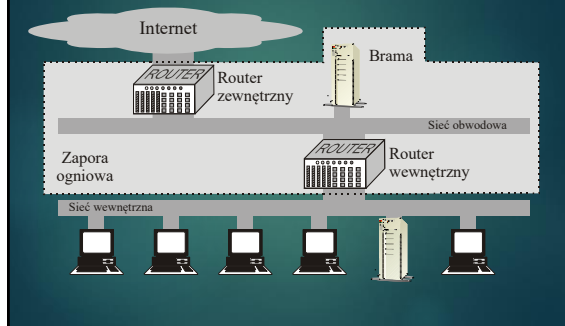
Zadania bramy:

- ▶ W bramie działa serwer poczty oraz serwery proxy

Ekranowany host – wady

- ▶ Intruz, który złamał zabezpieczenia hosta bastionowego uzyskuje łatwy dostęp do wszystkich wewnętrznych hostów
- ▶ Sieć jest dostępna, gdy intruz złamie zabezpieczenia routera
- ▶ W bastionie nie należy uruchamiać ryzykownych usług

Ekranowana podsieć



Ekranowana podsieć

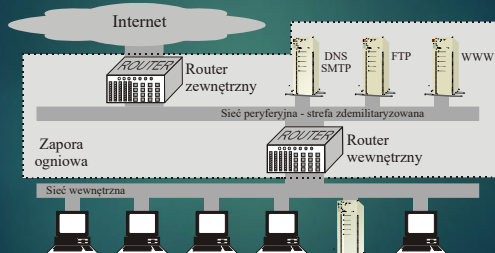
Nowe zadania routera zewnętrznego:

- ▶ Blokowanie pakietów adresowanych do routera wewnętrznego

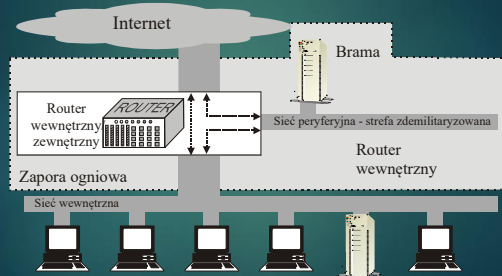
Zadania routera **wewnętrznego**:

- ▶ Blokowanie usług niewykorzystywanych w sieci wewnętrznej
- ▶ Blokowanie pakietów przesyłanych z routingiem źródłowym
- ▶ Blokowanie pakietów adresowanych do routera zewnętrznego
- ▶ Przepuszczanie pakietów, których źródłowym bądź docelowym adresem IP jest adres bramy. Porty muszą odpowiadać portom zdefiniowanym przez programy proxy działające w bramie

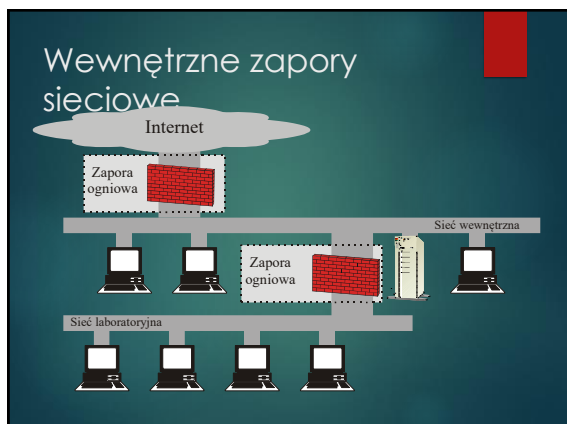
Architektura z użyciem większej liczby bram



Zespolony ruter zewnętrzny i wewnętrzny



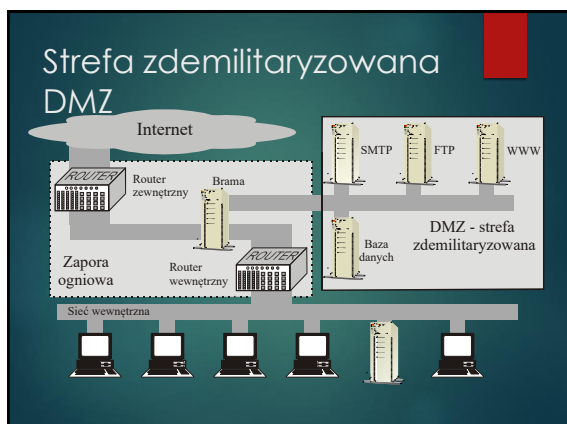
Wewnętrzne zapory sieciowe



Wewnętrzne zapory sieciowe

- ▶ Zastosowanie komputerów pełniących rolę wewnętrznej zapory sieciowej oraz ich odpowiednia konfiguracja, może pozytywnie wpłynąć na **ograniczenie szkód** wyrządzonych w sieci lokalnej
- ▶ Badania dowodzą, że **wiele włamań** odbywa się z **wewnątrz sieci lokalnej**, stąd potrzeba lepszej ochrony jej fragmentów
- ▶ **Ograniczają** skutki fizycznych awarii w sieci wewnętrznej do mniejszej liczby komputerów
- ▶ **Ograniczają** liczbę hostów, które mogą być podatne na ataki przez uniemożliwienie działania
- ▶ Tworzą **bariery** dla włamywaczy z zewnątrz (z Internetu) jak i z wewnątrz (z sieci lokalnej)

Strefa zdemilitaryzowana DMZ



Strefa zdemilitaryzowana DMZ

- ▶ Strefa zdemilitaryzowana **DMZ** (ang. *De-Militarized Zone*) zwana również siecią peryferyjną (ang. *perimeter network*) to sieć utworzona między siecią chronioną a zewnętrzną w celu zapewnienia dodatkowej warstwy zabezpieczeń
- ▶ W tej strefie często umieszczane są serwery zawierające usługi udostępniane **publicznie** użytkownikom z zewnątrz, np. serwer WWW, bazy danych

Złożone konfiguracje zapór ogniowych

- ▶ Dla bardziej złożonych środowisk, z wieloma sieciami LAN istnieje możliwość **kaskadowania firewalli**, czyli tworzenia zagnieżdżonych w sobie stref bezpieczeństwa chronionych przez kolejne zapory
- ▶ W tym celu można stosować konfiguracje **zawierające wiele** ekranowanych sieci, routerów zewnętrznych bądź wewnętrznych, hostów bastionowych, stref DMZ

Kryteria oceny zapory ogniowej

- ▶ Skalowalność
- ▶ Niezawodność i nadmiarowość
- ▶ Raportowanie
- ▶ Cena
- ▶ Zarządzanie i konfiguracja
- ▶ Odpowiedniość i możliwość przystosowania
- ▶ Współpraca z innymi systemami

Podsumowanie wiadomości o zaporach ogniowych

- ▶ Cały ruch w obu kierunkach do i z chronionej sieci LAN **musi** przechodzić przez zaporę ogniową
- ▶ Zapora zezwala na przejście tylko tych danych, które są **autoryzowane** przez lokalne zasady bezpieczeństwa
- ▶ Zapora musi być **odporna na penetrację** z zewnątrz i z wewnątrz
- ▶ **Firewall nie rozwiązuje całkowicie problemu bezpieczeństwa**, jest tylko jednym z elementów systemu

Podsumowanie wiadomości o zaporach ogniowych

- ▶ Pełny firewall to nie tylko filtrowanie ruchu sieciowego, ale także **współpraca** z systemami identyfikacyjnymi, szyfrującymi i monitorującymi
- ▶ Firewall wymaga **prawidłowej konfiguracji**, zarządzania i aktualizacji, inaczej nie będzie spełniał swoich zadań
- ▶ Do poprawnej implementacji i konfiguracji zapory ogniowej niezbędna jest **jasna polityka bezpieczeństwa**
- ▶ Na rynku **oferowanych** jest **wiele różnych firewalli**: sprzętowe, programowe, indywidualne, itd

Przykłady konfiguracji reguł filtrowania

- ▶ Zezwolić na cały ruch IP między zaufanym hostem zewnętrznym (172.16.51.50) a hostami w sieci wewnętrznej (klasa C: 192.168.10.0)

Reguła	Kierunek	Adres źródłowy	Adres docelowy	Protokół	Działanie
A	Przychodzące	Zaufany host zewn.	Wewnętrzny	Dowolny	Pozwól
B	Wychodzące	Wewnętrzny	Zaufany host zewnętrzny	Dowolny	Pozwól
C	Wszystkie	Dowolny	Dowolny	Dowolny	Zabroń

Przykłady konfiguracji reguł filtrowania

Reg	Adres źródłowy	Maska	Adres docelowy	Maska	Protokół	Działanie
1	172.16.51.50	0.0.0.0	192.168.10.0	0.0.0.255	Dowolny	Pozwól
2	192.168.10.0	0.0.0.255	172.16.51.50	0.0.0.0	Dowolny	Pozwól
3	0.0.0.0	255.255.255.255	0.0.0.0	255.255.255.255	Dowolny	Zabroń

Plan wykładu

- ▶ Wprowadzenie
- ▶ Zapory ogniowe
- ▶ **Systemy IDS**
- ▶ Systemy IPS
- ▶ Systemy UTM
- ▶ Podsumowanie

Systemy IDS

- ▶ **IDS** (ang. *Intrusion Detection System*) to system wykrywania włamań pozwalający na monitorowanie ataków,
- ▶ Stosowana są **techniki**: analizy ruchu sieciowego, wykrywania zdefiniowanych sygnatur, raportowania ogólnych nieprawidłowości komunikacyjnych
- ▶ Niektóre systemy IDS oparte są o zdolne do nauki algorytmy **heurystyczne**, które automatycznie dostosowują się do danej sieci
- ▶ System IDS **składa się z**: sensorów, konsoli i mechanizmu analizującego informacje

Rodzaje systemów IDS

- ▶ **Network IDS** to niezależna platforma która analizuje ruchu sieciowy i monitoruje wiele stacji połączonych siecią. System Network IDS uzyskuje dostęp do danych poprzez podłączenie do urządzeń sieciowych (przełącznik, ruter) za pomocą specjalnego portu
- ▶ **Protocol-based IDS** to system, który kontroluje jeden wybrany protokół pomiędzy urządzeniami
- ▶ **Application-based IDS** analizuje konkretne protokoły związane z daną aplikacją, np. bazą danych SQL
- ▶ **Host-based IDS** składa się z oprogramowania agenta zainstalowanego na jednym komputerze i analizującego zachowanie systemu operacyjnego
- ▶ **Hybrid IDS** wykorzystujące dwa lub więcej koncepcji

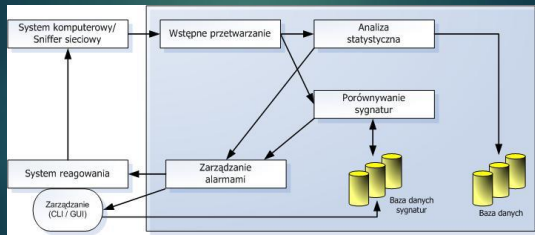
Mechanizmy IDS

- ▶ Metoda oparta na **sygnaturach** działa podobnie jak systemy antywirusowych, systemy przeszukują ruch w sieci i porównują go z wzorcami znanych ataków
- ▶ Metoda **behawioralna**, opiera się na obserwacji zachowań w sieci. IDS analizuje ruch sieciowy w określonych przedziałach czasu i tworzy wzorce typowego ruchu, używając skomplikowanych algorytmów matematycznych. Następnie takie wzorce pozwalają wykrywać nowe i podejrzanе zachowania w sieci odbiegające od normy

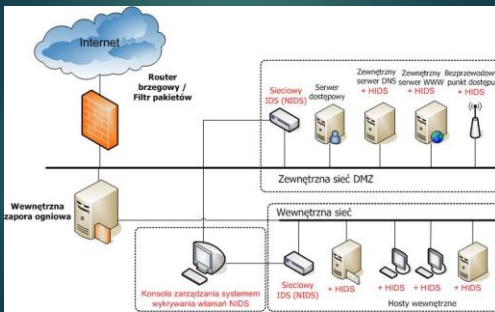
Normalne działanie, atak, anomalia

- ▶ Zmiana pliku z hasłami **Atak**
- ▶ Podanie błędnego hasła 4 razy pod rząd **Anomalia**
- ▶ Nieudane próby nawiązania połączenia na kolejnych 50 portach **Anomalia**
- ▶ Użytkownik logujący się normalnie o 10 rano z Warszawy loguje się o 3 rano z Pekinu **Anomalia**
- ▶ Pakiet UDP wysłany na port 1434 **Atak**
- ▶ Słowo DEBUG w pakiecie SMTP **Normalne działanie**

Schemat systemu IDS

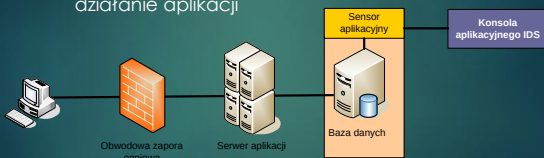


Sieciowy IDS



Aplikacyjny IDS

- Aplikacyjny IDS posiada sensory w poszczególnych aplikacjach i monitoruje działanie aplikacji



Warunki skuteczności IDS

- ▶ **Świadoma polityka bezpieczeństwa** - IDS nie wykryje zagrożenia jeżeli nie zostanie ono zdefiniowane
- ▶ **Właściwa klasyfikacja ruchu** - dla IDS dane o ruchu są wtedy użyteczne, jeżeli można to porównać z ruchem normalnym
- ▶ **Architektury IDS i lokalizacja sensorów** - użyteczność IDS zależy od ich implementowania oraz lokalizacji sensorów w sposób zapewniający uzyskiwanie użytecznej informacji

Plan wykładu

- ▶ Wprowadzenie
- ▶ Zapory ogniowe
- ▶ Systemy IDS
- ▶ **Systemy IPS**
- ▶ Systemy UTM
- ▶ Podsumowanie

Systemy IPS

- ▶ Sieciowe **IPS** (Intrusion Prevention System) to **aktywne** rozwiązania ochronne
- ▶ Systemy zapobiegania wtrąceniom zawierają większość funkcji IDS, ale dodatkowo potrafią **reagować na ataki i je blokować**
- ▶ Inną istotną różnicą pomiędzy systemami IDS i IPS polega też na tym, że IPS generalnie jest umieszczany **inline** (na drodze danych), tak że może wkroczyć do akcji i zablokować ruch, jeżeli stwierdzi objawy ataku
- ▶ IPS są budowane w postaci specjalizowanych **urządzeń**, podobnie jak przełączniki czy routery lub wykorzystują standardowe pecety

Kryteria wyboru IPS

- ▶ **Wydajność.** Ponieważ IPS pracują inline, muszą umożliwiać analizę wszystkich pakietów przechodzących przez niego bez wnoszenia nadmiernych opóźnień
- ▶ **Algorytm blokowania.** System powinien używać wielu środków (takich jak sygnatury, metody behawioralne i reguły polityki) do rozpoznawania i blokowania ataków
- ▶ **Raportowanie.** Konieczna jest zdolność oceny użytkownika IPS i generowania zarówno raportów
- ▶ **Interfejs.** Pożądany jest graficzny interfejs użytkownika, łatwy do opanowania przez administratorów

Plan wykładu

- ▶ Wprowadzenie
- ▶ Zapory ogniowe
- ▶ Systemy IDS
- ▶ Systemy IPS
- ▶ **Systemy UTM**
- ▶ Podsumowanie

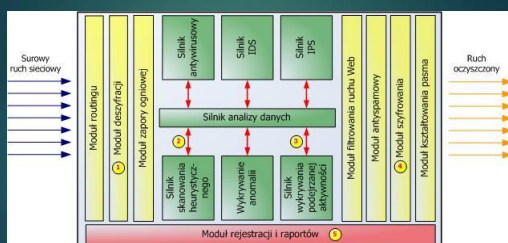
UTM

- ▶ Technologia **UTM** jest obecnie najbardziej zaawansowaną technologią systemów kontroli ruchu sieciowego
- ▶ Polega ona na **połączeniu** typowej zapory ogniowej i innych systemów zabezpieczających (w postaci modułów) w jedną całość, dzięki czemu możliwe jest dokładniejsze analizowanie przychodzącego i wychodzącego do i z organizacji ruchu sieciowego

Funkcje UTM

- ▶ Funkcje zapory ogniowej
- ▶ Funkcje systemów IDS/IPS
- ▶ Filtrowanie poczty email (ochrona antyspamowa),
- ▶ Kontrola antywirusowa,
- ▶ Filtrowanie zawartości stron WWW (np. dynamiczne usuwanie apletów Java, JavaScript czy też ActiveX),
- ▶ Analiza ruchu dla indywidualnych użytkowników sieci

Technologia UTM



Technologia UTM

1. Ruch wchodzący w razie potrzeby poddawany jest deszyfrowaniu przed wstępną kontrolą przez moduł zapory ogniowej
2. Silnik analizy danych ma za zadanie korelować kontrolę między poszczególnymi silnikami ochrony i modułami włączonymi do urządzenia UTM, automatycznie odrzucając każdy ruch zawierający potencjalne zagrożenia
3. Silnik analizy danych składa wielopakietowy ruch w celu umożliwienia jego analizy przez moduły antywirusowe, moduł filtrowania ruchu Web i moduł antyspamowy
4. Ruch VPN, lub inny ruch szyfrowany, jest ponownie szyfrowany w module szyfrowania
5. Wykryte zagrożenia raportowane są w module dziennika zdarzeń i raportów, który wykorzystywany jest do generowania alarmów

Plan wykładu

- ▶ Wprowadzenie
- ▶ Zapory ogniowe
- ▶ Systemy IDS
- ▶ Systemy IPS
- ▶ Systemy UTM
- ▶ **Podsumowanie**

Podsumowanie

- ▶ Systemy kontroli ruchu sieciowego to **podstawowy** mechanizm stosowany w celu zabezpieczenia sieci
- ▶ Początkowo tą funkcję realizowały **zapory ogniowe**, które obecnie są wspierane przez systemy **IDS i IPS**
- ▶ Systemy **UTM** integrują funkcje bezpieczeństwa w jednym urządzeniu
- ▶ Aby systemy kontroli ruchu sieciowego skutecznie zabezpieczały sieć, niezbędna jest odpowiednia ich **konfiguracja wynikająca z polityki bezpieczeństwa**